ELSEWEDEY UNIVERSITY OF TECHNOLOGY
School of Engineering Technology
Program: Cyber Security

REPORT

Cybersecurity Standards & Egyptian Laws

Course Name: Cyber & Information Security
Course Code: CET231
Instructor: Dr. Mohamed Nabil Hassan

Student Name: Moaaz
Student ID: 240100323
Academic Year: 2026/2027

Table of Contents

1. International Standards

1.1 ISO/IEC 27001:2022

1.2 NIST Cybersecurity Framework

2. Industry-Specific Regulations

2.1 HIPAA

2.2 GDPR

3. Egyptian Legal Frameworks

3.1 Law No. 175/2018 on Cybercrime

3.2 Law No. 151/2020 on Personal Data Protection

3.3 Comparison with GDPR

3.4 NTRA Licensing Requirements

1. International Standards

1.1 ISO/IEC 27001:2022

What It Requires

ISO/IEC 27001:2022 specifies requirements for an Information Security Management System (ISMS). Organizations define the ISMS scope, establish security policies and responsibilities, assess information-security risks, select risk-treatment measures, document processes, train staff, monitor performance, conduct internal audits and management reviews, correct problems, and continually improve the system. Annex A provides a reference set of security controls considered during risk treatment; controls are selected according to the organization’s risks and documented in its Statement of Applicability.

Which Organizations Must Comply

The standard can be used by organizations of any size and sector. It is generally voluntary, but it may be required by a regulator, contract, customer, or procurement condition. Certification is an independent assessment of an ISMS; it does not guarantee that security incidents will never occur.

1.2 NIST Cybersecurity Framework (CSF 2.0)

What It Requires

NIST CSF 2.0 organizes cybersecurity outcomes into six functions: Govern (strategy, policy, roles, and oversight); Identify (assets and risks); Protect (safeguards such as access control and training); Detect (identify and analyze events); Respond (contain and manage incidents); and Recover (restore services and improve resilience). Organizations can compare their current and target profiles and prioritize improvements. The framework is guidance, not a single mandatory checklist.

Which Organizations Must Comply

CSF 2.0 is designed for organizations of all sizes and sectors, including public, private, and nonprofit organizations. Use is generally voluntary unless required by law, regulation, policy, or contract.

2. Industry-Specific Regulations

2.1 HIPAA (Health Insurance Portability and Accountability Act)

What Data It Protects

HIPAA protects individually identifiable health information, known as Protected Health Information (PHI), when handled by covered entities and their business associates. It relates to a person's health condition, healthcare, or payment for healthcare. The Privacy Rule governs uses and disclosures, the Security Rule protects electronic PHI, and the Breach Notification Rule requires notification for certain breaches. HIPAA does not automatically apply to every organization that holds health-related information.

Real Enforcement Case

On 14 January 2025, the U.S. Department of Health and Human Services announced a $3 million settlement with Solara Medical Supplies following a HIPAA investigation involving a phishing attack. The case highlights the importance of risk analysis, phishing protection, workforce awareness, and appropriate security controls.

2.2 GDPR (General Data Protection Regulation)

What Data It Protects

The GDPR protects personal data relating to an identified or identifiable person. Examples include names, contact details, online identifiers, location data, and health information. It gives additional protection to special categories such as health, genetic, and certain biometric data, and information revealing political opinions or religious beliefs. Core requirements include lawful and transparent processing, purpose limitation, data minimization, accuracy, limited retention, security, accountability, data-subject rights, and safeguards for international transfers.

Real Enforcement Case

On 12 May 2023, Ireland's Data Protection Commission issued a decision concerning Meta Platforms Ireland's transfers of Facebook users' personal data from the EU/EEA to the United States. The decision imposed a €1.2 billion fine and required suspension of the specified transfers unless compliant safeguards were implemented. The case demonstrates the importance of lawful cross-border data-transfer mechanisms.

3. Egyptian Legal Frameworks

3.1 Law No. 175/2018 on Cybercrime — What It Regulates

Egypt's Law No. 175 of 2018 addresses crimes involving information technology and information systems. It covers conduct such as unauthorized access, exceeding authorized access, attacks on systems or data, interference with services, and certain forms of misuse of information technology. It also sets obligations for service providers, including protecting stored data and supporting lawful investigative procedures. Users and organizations should access systems only with authorization and preserve relevant digital evidence during incident handling.

3.2 Law No. 151/2020 on Personal Data Protection (PDPL) — What It Regulates

Law No. 151 of 2020 regulates electronic processing of personal data within its scope. It addresses collection, use, storage, and transfer of personal data and establishes duties for entities processing data, alongside rights for data subjects. Compliance involves lawful processing, transparency, data security, respect for applicable rights, and meeting relevant permit, licensing, and transfer requirements. The law establishes the Personal Data Protection Center; organizations should consult the law, applicable executive regulations, and current regulator decisions.

3.3 Comparison with GDPR

Topic	Egyptian PDPL	GDPR
Scope	Electronic personal data within the Egyptian law's scope.	Personal data processing within the GDPR's territorial scope.
Authority	Personal Data Protection Center.	Independent EU Member State supervisory authorities.
Main duties	Lawful processing, security, rights, and applicable permit/transfer controls.	Lawfulness, transparency, minimization, accountability, rights, and transfer safeguards.
Practical point	Check Law 151/2020 and applicable Egyptian regulations.	Check GDPR and relevant national rules and regulator decisions.

Both laws protect personal data, but their territorial scope, regulator structures, and detailed procedures differ. An organization operating in both jurisdictions may need to comply with both; compliance with one does not automatically satisfy the other.

3.4 NTRA Licensing Requirements — What It Regulates

The National Telecommunications Regulatory Authority (NTRA) regulates telecommunications services in Egypt and publishes rules for relevant providers. Its cybersecurity-services regulatory framework may require providers offering covered cybersecurity services to meet registration, accreditation, technical, or organizational conditions. Organizations should check whether their specific service falls under the framework and confirm current requirements directly with NTRA. These requirements should not be treated as a universal license for every organization that simply uses cybersecurity tools.

References

1. ISO. ISO/IEC 27001:2022 — Information security management systems — Requirements. https://www.iso.org/standard/27001.html

2. NIST. The NIST Cybersecurity Framework (CSF) 2.0, 2024. https://doi.org/10.6028/NIST.CSWP.29

3. U.S. Department of Health and Human Services, Office for Civil Rights. HIPAA enforcement announcements and resolution agreements. https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/agreements/index.html

4. Regulation (EU) 2016/679 (General Data Protection Regulation). https://eur-lex.europa.eu/eli/reg/2016/679/oj

5. Ireland Data Protection Commission. Meta Platforms Ireland decision concerning EU/EEA–US data transfers, 12 May 2023. https://www.dataprotection.ie/

6. Egypt, Law No. 175 of 2018 on Combating Information Technology Crimes. https://www.wipo.int/wipolex/en/legislation/details/19959

7. Egypt, Law No. 151 of 2020 on Personal Data Protection. Personal Data Protection Center: https://www.pdpc.gov.eg/

8. National Telecommunications Regulatory Authority (NTRA), Egypt. https://www.tra.gov.eg/